Phishing Email Detection Report

Security Awareness & Threat Analysis

GANDONOU Koffi Patrick-Léon

Cyber Security Intern - Future Interns Program

March 22, 2026

Table of Contents

Right-click the TOC and select "Update Field" to refresh page numbers

Executive Summary **3**

About Phishing **4**

What is Phishing? 4

Why Is It So Effective? 4

The Cost 5

Phishing Email Samples Analyzed **6**

Sample 1 - PayPal Account Suspended 6

Sample 2 - CEO Wire Transfer 7

Sample 3 - IT Password Reset 8

Risk Classification Summary **9**

How Phishing Attacks Work **10**

Prevention Guidelines for Users **11**

Do's and Don'ts for Employees **12**

Conclusion **13**

1. Executive Summary

Phishing is consistently ranked as the **#1 initial attack vector** in corporate data breaches worldwide.

This report analyzes **3 real-world phishing email scenarios** - from a classic credential-harvesting email to a sophisticated CEO fraud (Business Email Compromise). Each sample is dissected to identify exactly how attackers craft these messages and what red flags employees can spot.

The goal is not to teach hacking - it is to teach employees how to **think like a security analyst** when reading their inbox, transforming them from the weakest link into a human firewall.

> **Key Finding:** All 3 phishing samples analyzed used emotional manipulation (urgency, fear, authority) as the primary attack mechanism. No advanced technical skills are needed by the attacker; human psychology is the vulnerability.

2. About Phishing

What is Phishing?

Phishing is a social engineering attack where a cybercriminal disguises themselves as a trustworthy entity - a bank, a colleague, a tech company - to trick a victim into:

- Clicking malicious links that steal credentials
- Downloading infected attachments that install malware
- Sharing sensitive information (passwords, OTPs, financial details)

Why Is It So Effective?

Unlike most attacks, phishing does not require breaking through firewalls or exploiting code. It exploits **human psychology** - specifically:

- Trust - "This email is from my bank / my CEO"
- Urgency - "I must act now or lose access"
- Authority - "This person is senior to me, I should comply"
- Fear - "My account will be suspended"

The Cost

- The average BEC (Business Email Compromise) attack costs organizations $120,000+ per incident (FBI IC3 Report)
- 91% of all cyberattacks begin with a phishing email (PhishMe Research)

3. Phishing Email Samples Analyzed

Sample 1 - PayPal Account Suspended

Type	Classic Credential Phishing
Impersonating	PayPal
Attack Goal	Steal PayPal login credentials
Classification	PHISHING - HIGH RISK

Sender: security@paypa1-accounts.com (Real PayPal: security@paypal.com)

The attack in plain English:
The attacker created a fake domain 'paypa1-accounts.com' that looks almost identical to 'paypal.com' - swapping the letter "l" for the number "1". The email body creates panic ("your account will be locked in 24 hours") to force the victim to click without thinking. The link goes to a fake lookalike PayPal site that captures their username and password.

Key Red Flags Identified:

#	Red Flag	What to Look For
1	Spoofed sender domain	paypa1-accounts.com -> '1' instead of 'l'
2	Urgency	"24 hours... permanent suspension"
3	Generic greeting	"Dear PayPal User" - not your actual name
4	Suspicious link URL	Hover over the link - does the domain match?
5	Reply-To mismatch	Replies go to a different attacker-controlled domain
6	No digital signature	Legitimate PayPal emails are cryptographically signed (DKIM)

Sample 2 - CEO Wire Transfer (Business Email Compromise)

Type	Business Email Compromise (BEC) / CEO Fraud
Impersonating	Company CEO
Attack Goal	Wire $47,500 to an attacker-controlled account
Classification	PHISHING - CRITICAL RISK

The attack in plain English:

The attacker researched LinkedIn to identify the company CEO and finance team. They registered a lookalike domain ('corporategmai1.com' instead of 'corporategmail.com') and sent an urgent wire transfer request impersonating the CEO. By adding "I'm in a board meeting and can't be reached by phone" and "This is strictly confidential", the attacker isolated the victim from verifying the request with colleagues or calling their boss.

Key Red Flags Identified:

#	Red Flag	What to Look For
1	Lookalike email domain	gmai1.com - '1' used instead of 'l'
2	Urgency + Secrecy	"Today" and "Don't tell colleagues"
3	Phone unavailability	"Cannot be reached by phone" - classic isolation tactic
4	Offshore bank destination	Wire to Cayman Islands account - irreversible
5	No prior communication	Out-of-the-blue request with no context

Sample 3 - IT Password Reset (Spear Phishing)

Type	Internal Spear Phishing
Impersonating	IT Security Department
Attack Goal	Steal corporate credentials via fake password reset page
Classification	SUSPICIOUS - Verify Before Clicking

The attack in plain English:

The attacker crafted a targeted email appearing to come from IT, using professional language and an urgent deadline. The link points to a Firebase-hosted fake page ('web.app') - not a corporate internal portal. Many employees click because they trust IT communications without checking the link destination.

4. Risk Classification Summary

Sample	Type	Classification
PayPal Account Suspended	Credential Phishing	PHISHING
CEO Wire Transfer Request	Business Email Compromise	PHISHING (Critical)
IT Password Reset Link	Spear Phishing	SUSPICIOUS

Classification Framework

SAFE	Verified sender, expected content, no suspicious links
SUSPICIOUS	One or more unusual elements - verify before acting
PHISHING	Multiple clear indicators - do not click, report immediately

5. How Phishing Attacks Work

The Phishing Attack Lifecycle

1. RECONNAISSANCE	Attacker researches target (LinkedIn, company website)
2. PREPARATION	Fake domain registered, lookalike email crafted
3. DELIVERY	Email sent to target's inbox (often bypasses spam filters)
4. EXECUTION	Victim clicks link / opens attachment / sends credentials
5. COMPROMISE	Attacker gains access to accounts, data, or funds

Most Common Phishing Techniques

Technique	How It Works
Typosquatting	Registers domain nearly identical to real one (paypa1 vs paypal)
Email Spoofing	Forges the "From" field to look like a trusted sender
Urgency/Fear	Creates time pressure to prevent careful thinking
Authority Abuse	Impersonates CEO, IT, bank, or government

Technique	How It Works
Link Obfuscation	Hides malicious URL behind "Click Here" button text
Look-alike Pages	Creates pixel-perfect copy of login pages

6. Prevention Guidelines for Users

Before Clicking Any Link

0. **Hover over the link**: Does the URL match the claimed sender? Look for typos.
1. **Check the sender's email address**: Look at the FULL email, not just the display name.
2. **Go directly to the website**: Type the URL yourself instead of clicking the link.
3. **Call to verify**: For any financial or urgent request, pick up the phone.

Recognizing Warning Signs

Warning Sign	Example
Urgency / Threats	"Your account will be closed in 24 hours"
Generic greeting	"Dear User", "Dear Customer"
Suspicious sender	support@amaz0n-help.com
Unusual request	CEO asking for a wire transfer by email
Suspicious attachment	.exe, .zip, .docm files
Mismatched URL	Link says "paypal.com" but leads to "paypa1.net"

7. Do's and Don'ts for Employees

DO	DON'T
Verify unexpected requests via a separate channel (call)	Don't click links in urgent, unexpected emails
Check the sender's full email address, not just the name	Don't trust display names alone
Report suspicious emails to IT / Security team	Don't forward or reply to phishing emails
Use MFA (Multi-Factor Authentication) on all accounts	Don't enter credentials without verifying the URL

DO	DON'T
Keep your devices and browsers updated	Don't open unexpected attachments
Hover over links before clicking	Don't wire money based on email instructions alone

8. Conclusion

Phishing attacks succeed not because employees are careless, but because attackers are skilled at exploiting human psychology. The best defences are:

4. **Awareness**: Employees who know what to look for are the strongest security layer
5. **Verification culture**: Build a habit of verifying unusual requests via a second channel
6. **Technical controls**: DKIM, SPF, DMARC email authentication; MFA on all accounts

> **Remember:** If something feels wrong about an email, trust your instincts. Taking 30 seconds to verify a request can save your organization hundreds of thousands of dollars.

Phishing Email Detection Report

Security Awareness & Threat Analysis

GANDONOU Koffi Patrick-Leon

Cyber Security Intern - Future Interns Program

© 2026 - Internal / Training Use